

Penetration Testing Report

Mediroza General Hospital Web Infrastructure

Client: Mediroza General Hospital

Target: <https://medirozahospital.com>

Engagement Type: Full Black Box Penetration Test

Conducted By: CHUKWU PRAISEGOD

Conducted Under: Networkwalks Internship Program

Authorization: Written authorization granted by the client for the stated scope and timeline

Engagement Duration: 5 days

Report Classification: Confidential, Client Use Only

1. Executive Summary

This engagement was carried out by [Your Name], an intern at Networkwalks, as part of a training engagement against the public facing web infrastructure of Mediroza General Hospital, specifically the domain medirozahospital.com. The objective of the engagement was to assess the real world security posture of the hospital's website and patient facing systems by actively attempting to identify and exploit vulnerabilities, rather than relying solely on automated scanning.

The assessment identified a Critical severity SQL Injection vulnerability in the patient portal login form. This flaw allowed an unauthenticated attacker to bypass authentication entirely and gain unrestricted access to a restricted patient area, from which three confidential patient lab report PDFs were retrieved without any valid credentials.

Further analysis of the retrieved PDF files showed that two of the three documents were protected with weak passwords that were recovered within minutes using a publicly available wordlist, undermining the confidentiality controls placed on sensitive patient health information.

During review of the recovered files, metadata embedded in the documents referenced an old backup directory that had not been removed from the live web server during a prior site migration. This directory was found to be publicly accessible with no authentication in place, and contained highly sensitive business records, including the salaries of all hospital employees and the shareholder details of the organisation.

Taken together, these findings represent a serious and realistic compromise path: an external attacker with no prior access or credentials could move from the public website, through a vulnerable login form, to confidential patient health records, and ultimately to sensitive internal business and financial data. The issues identified are assessed as presenting a Critical overall risk to the client and are recommended for immediate remediation.

2. Scope and Methodology

2.1 Scope

Target: <https://medirozahospital.com> and its associated web infrastructure

Testing Type: Full black box penetration test, no prior credentials or internal knowledge provided

Rules of Engagement: Testing limited strictly to the target domain, no social engineering, no denial of service testing, no testing outside the agreed scope

Authorization: Written authorization for security testing was provided by the client prior to commencement

This report documents only the activities, techniques and findings that are directly relevant to achieving the agreed engagement objectives. Reconnaissance activity performed against infrastructure outside the practical scope of the objectives, such as unrelated mail server hardening checks, is summarised briefly for completeness where it informed the overall assessment, but is not treated as a standalone finding.

2.2 Methodology

The assessment followed a structured approach consistent with industry standard penetration testing methodology, broken down into the phases below.

Phase 1: Reconnaissance

- Performed network and service enumeration using Nmap against the target host to identify exposed services, including HTTP and HTTPS delivered through a HAProxy load balancer, a mail stack (Exim and Dovecot), DNS (BIND), FTP (Pure-FTPd), cPanel related services, and SSH on a non default port.
- Confirmed the host sits on shared hosting infrastructure and identified additional in scope IP addresses referenced in the domain's SPF record.
- Performed DNS reconnaissance, including a zone transfer attempt (refused, as expected on a correctly configured name server) and an ANY query that revealed mail routing and SPF details.
- Performed directory and content discovery against the live application using Gobuster, which revealed the presence of a WordPress installation (wp-admin), a staff facing directory, a mailman and pipermail archive, and a directory named old that returned a redirect response.
- Tested the mail service for an open relay condition and for SMTP user enumeration via the VRFY command. Both tests returned negative results, indicating a correctly hardened mail configuration. These checks are noted for completeness but did not contribute to the exploitation path described in this report.

Phase 2: Identification of Entry Points and Authentication Analysis

- Identified two authentication protected entry points on the application: a Patient Portal at /patient/login.php and a Staff Login at /staff/login.php, both generated by a bespoke content management system identified in page metadata as Mediroza CMS version 1.4.2.
- Analysed the behaviour of both login forms under invalid, guessed, and default credential submissions, recording the exact error response text returned for each case.

Phase 3: Exploitation

- Exploited a SQL Injection vulnerability in the Patient Portal login form to bypass authentication and access a restricted patient area.
- Retrieved three confidential PDF lab reports from the compromised patient area.
- Extracted password hashes from the retrieved PDF files and performed offline password cracking to recover their contents.
- Performed metadata analysis on the decrypted PDF files, which revealed a reference to a legacy backup location on the web server.
- Accessed the referenced directory directly and confirmed it was publicly exposed with no access control, containing highly sensitive staff salary and shareholder data.

Phase 4: Documentation

- All actions, commands, responses and evidence were logged throughout the engagement and are presented in Section 3 of this report.

2.3 Tools Used

- Nmap, for network and service enumeration
- Gobuster, for subdomain and directory and file discovery
- dig and dnsrecon, for DNS enumeration
- curl, swaks and netcat (nc), for manual service interaction and protocol level testing
- Burp Suite or an equivalent browser based testing approach, for manual authentication and input handling analysis
- John the Ripper (pdf2john.pl), for extracting crackable hash representations of PDF encryption
- Hashcat, for offline password recovery against PDF encryption hashes
- ExifTool, for PDF metadata analysis
- rockyou.txt, as the primary password wordlist

2.4 Limitations and Notes on Methodology

Password hash extraction and cracking for the three retrieved PDF files was initially attempted using Networkwalks' own online hash calculator and password cracker utilities. This approach successfully recovered the passwords for patient_report_1.pdf and patient_report_2.pdf, but was unable to recover the password for patient_report_3.pdf due to the limited wordlist available to that online tool.

To resolve this, the hash extraction and cracking process was repeated locally using John the Ripper's pdf2john.pl script to generate the hash files, followed by Hashcat (mode 10500, RC4 128 bit PDF encryption) using the rockyou.txt wordlist. This local approach successfully recovered the passwords for all three files. For future engagements involving genuinely confidential or regulated data such as real patient health information, it is recommended to perform hash extraction and cracking entirely with local, offline tooling from the outset, rather than submitting sensitive files or derived hashes to third party online services, in order to avoid any unnecessary exposure of client data.

3. Findings and Proof of Exploitation

Finding 1: SQL Injection Leading to Authentication Bypass (Milestone 1)

Location: <https://medirozahospital.com/patient/login.php>

Risk Rating: Critical

The Patient Portal login form submits a username and password via POST to login.php. Behavioural testing of the form revealed a username enumeration weakness: submitting an invalid username consistently returned the message "username not found", while submitting the username admin with an incorrect password returned a different message, "incorrect password". This confirmed the existence of a valid account named admin on the patient facing login, and indicated the backend performs a database lookup on the username before evaluating the password, a pattern commonly associated with unsanitised SQL query construction.

Based on this behaviour, a classic SQL Injection authentication bypass payload was submitted in the username field:

Username: admin'--

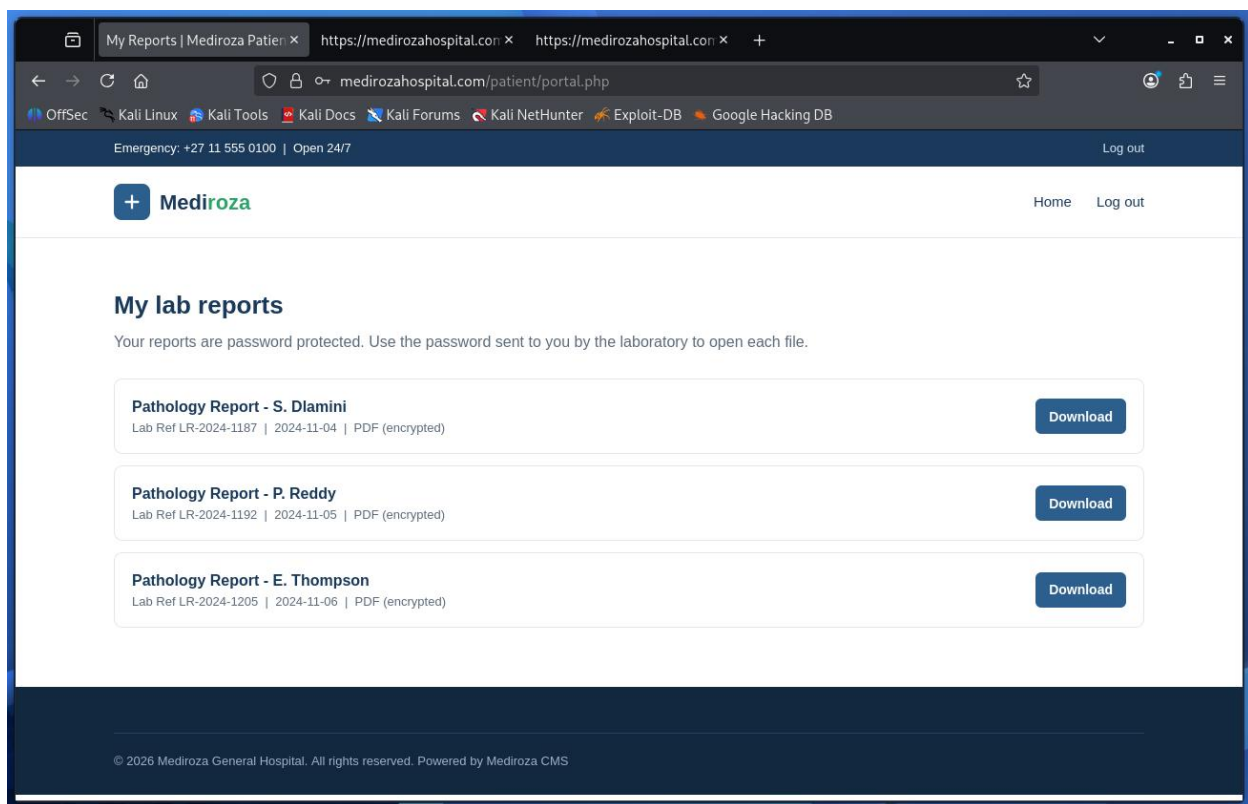
Password: (any value)

This payload successfully bypassed authentication entirely, granting access to the patient dashboard without knowledge of a valid password. The payload comments out the remainder of the backend SQL query, most likely a statement structured similarly to the following, causing the password check to be skipped:

```
SELECT * FROM users WHERE username = 'admin'--' AND password = '...'
```

Upon successful bypass, the application granted access to a restricted patient area containing three confidential PDF lab reports, which were downloaded directly: patient_report_1.pdf, patient_report_2.pdf, and patient_report_3.pdf. This fully satisfies the Milestone 1 objective and represents a complete compromise of the application's authentication control for the patient facing area.

Proof of Exploitation



Finding 2: Username Enumeration on Patient Portal Login (Milestone 1)

Location: <https://medirozahospital.com/patient/login.php>

Risk Rating: Medium

As described above, the Patient Portal returns distinguishable error messages depending on whether a submitted username exists in the system, specifically "username not found" for unknown usernames versus "incorrect password" for a known username with a wrong password. This behaviour allows an attacker to enumerate valid account names without needing to guess a password, which materially increases the efficiency of any subsequent credential based attack, such as credential stuffing or password spraying. By contrast, the Staff Login form at /staff/login.php was tested in the same manner and consistently returned a single generic message, "invalid username or password", for all invalid combinations tested, demonstrating that this weakness is specific to the Patient Portal implementation.

Finding 3: Weak, Crackable PDF Encryption Passwords (Milestone 2)

Location: patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf

Risk Rating: High

Each of the three PDF lab reports retrieved in Milestone 1 was protected using standard PDF encryption. Inspection of the encryption parameters confirmed all three files used RC4 128 bit encryption with a user password required to open the document (PDF encryption revision V2, R3).

Password hashes suitable for offline cracking were extracted from each file using John the Ripper's pdf2john.pl utility:

```
perl /usr/share/john/pdf2john.pl patient_report_1.pdf > patient_report_1.hash
perl /usr/share/john/pdf2john.pl patient_report_2.pdf > patient_report_2.hash
perl /usr/share/john/pdf2john.pl patient_report_3.pdf > patient_report_3.hash
```

Before the resulting hash files could be accepted by Hashcat, the leading filename prefix written by pdf2john.pl, for example patient_report_1.pdf:, had to be manually removed from each file using a text editor. Each file was then cracked using Hashcat in mode 10500, the mode corresponding to 128 bit RC4 encrypted PDF files, against the rockyou.txt wordlist:

```
hashcat -m 10500 patient_report_1.hash /usr/share/wordlists/rockyou.txt
hashcat -m 10500 patient_report_2.hash /usr/share/wordlists/rockyou.txt
hashcat -m 10500 patient_report_3.hash /usr/share/wordlists/rockyou.txt
```

All three passwords were successfully recovered using the rockyou.txt wordlist, confirming that the passwords protecting patient health information were weak, common, and present in a widely available password list. This represents a significant failure of the confidentiality control intended to protect this data, since encryption that can be defeated within minutes using a freely available wordlist provides negligible real world protection.

Proof of Exploitation

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x
$pdf$2*3*128*4294967292*1*32*3261393066326130336634386337323631306164373264323130316137616538*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e75
8a4164004e56fffa0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8: !@#$$%^&

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 10500 (PDF 1.4 - 1.6 (Acrobat 5 - 8))
Hash.Target.....: $pdf$2*3*128*4294967292*1*32*3261393066326130336634 ... 40c1f8
Time.Started.....: Thu Oct 1 11:57:28 2026 (1 sec)
Time.Estimated...: Thu Oct 1 11:57:29 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-32 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 46970 H/s (12.00ms) @ Accel:291 Loops:70 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 72751/14344385 (0.51%)
Rejected.....: 1/72751 (0.00%)
Restore.Point...: 72169/14344385 (0.50%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-70
Candidate.Engine.: Device Generator
Candidates.#01...: 02081991 -> peniss
Hardware.Mon.#01.: Util: 4%

Started: Thu Oct 1 11:57:26 2026
Stopped: Thu Oct 1 11:57:31 2026

kali@kali)~/(Downloads)
$ hashcat -m 10500 patient_report_1.hash --show
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e75
8a4164004e56fffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6:123456 ←

kali@kali)~/(Downloads)
$ hashcat -m 10500 patient_report_2.hash --show
$pdf$2*3*128*4294967292*1*32*3166346338373236356437626464363834663737303265633666363264663*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e75
8a4164004e56fffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775:password ←

kali@kali)~/(Downloads)
$ hashcat -m 10500 patient_report_3.hash --show
$pdf$2*3*128*4294967292*1*32*3261393066326130336634386337323631306164373264323130316137616538*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e75
8a4164004e56fffa0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8: !@#$$%^& ←

kali@kali)~/(Downloads)
$
```

medirozahospital.com/old/m/Pathology Report - S. DlaminiPathology Report - P. ReddyPathology Report - E. Thomp

file:///home/kali/Downloads/patient_report_1.pdf

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

1 of 190%

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Sipho Dlamini

Patient ID:

MG-P-10231

Date of Birth:

1984-06-12

Gender:

Male

Report Date:

2024-11-04

Referring Dr:

Dr. Anita Naicker

Specimen:

Whole blood (EDTA)

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

medirozahospital.com/old/m/Pathology Report - S. DlamirPathology Report - P. ReddyPathology Report - E. Thomp

file:///home/kali/Downloads/patient_report_2.pdf

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

1 of 190%

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Priya Reddy

Patient ID:

MG-P-10244

Date of Birth:

1991-02-28

Gender:

Female

Report Date:

2024-11-05

Referring Dr:

Dr. Johan van der Merwe

Specimen:

Serum

Lab Ref No:

LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

medirozahospital.com/old/m

Pathology Report - S. Dlamini

Pathology Report - P. Reddy

Pathology Report - E. Thomp

+

file:///home/kali/Downloads/patient_report_3.pdf

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 of 1

90%

14 Cedar Avenue, Johannesburg, South Africa
Teli: +27 11 555 0100
medirozahospital.com

+

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Teli: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: Emily Thompson

Patient ID: MG-P-10258

Date of Birth: 1978-09-03

Gender: Female

Report Date: 2024-11-06

Referring Dr: Dr. Ahmed Kara

Specimen: Serum

Lab Ref No: LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

Finding 4: Information Disclosure via PDF Metadata (Milestone 3)

Location: patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf

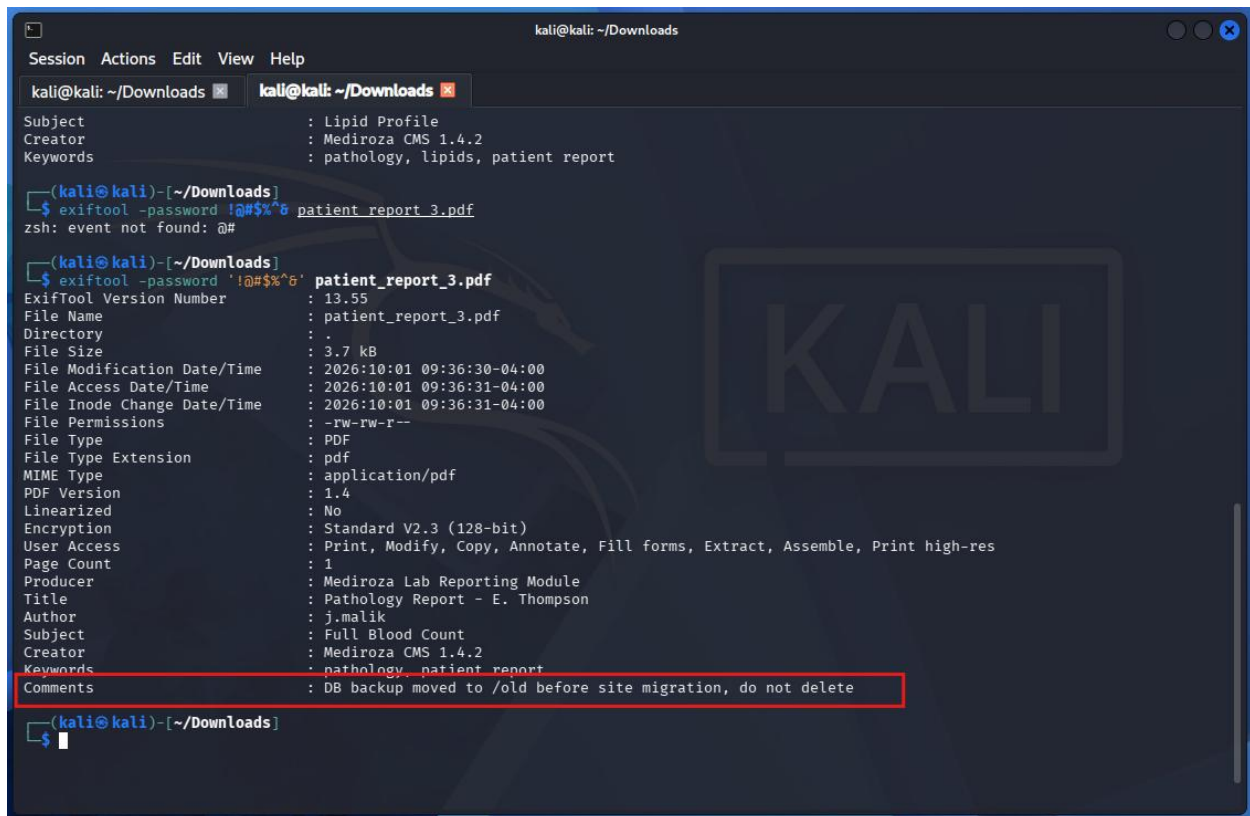
Risk Rating: Medium

Following successful decryption, the metadata of all three PDF files was reviewed using ExifTool with the decryption password supplied. This review identified a comment field embedded in the document metadata containing the following internal operational note:

Comment: DB backup moved to /old before site migration, do not delete

This note directly disclosed the existence and relative location of a legacy backup directory on the production web server. Internal notes of this nature should never be left in documents that may leave the organisation's internal custody, as they can directly inform an attacker's next steps, which is precisely what occurred in this engagement.

Proof of Exploitation



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x
Subject : Lipid Profile
Creator : Mediroza CMS 1.4.2
Keywords : pathology, lipids, patient report

(kali@kali)-[~/Downloads]
$ exiftool -password '!@#$$%^&' patient_report_3.pdf
zsh: event not found: @#

(kali@kali)-[~/Downloads]
$ exiftool -password '!@#$$%^&' patient_report_3.pdf
ExifTool Version Number : 13.55
File Name : patient_report_3.pdf
Directory : .
File Size : 3.7 kB
File Modification Date/Time : 2026:10:01 09:36:30-04:00
File Access Date/Time : 2026:10:01 09:36:31-04:00
File Inode Change Date/Time : 2026:10:01 09:36:31-04:00
File Permissions : -rw-rw-r--
File Type : PDF
File Type Extension : pdf
MIME Type : application/pdf
PDF Version : 1.4
Linearized : No
Encryption : Standard V2.3 (128-bit)
User Access : Print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print high-res
Page Count : 1
Producer : Mediroza Lab Reporting Module
Title : Pathology Report - E. Thompson
Author : j.malik
Subject : Full Blood Count
Creator : Mediroza CMS 1.4.2
Keywords : pathology, patient report
Comments : DB backup moved to /old before site migration, do not delete

(kali@kali)-[~/Downloads]
$
```

Finding 5: Critical Sensitive Data Exposure via Legacy Backup Directory (Milestone 3)

Location: <https://medirozahospital.com/old/>

Risk Rating: Critical

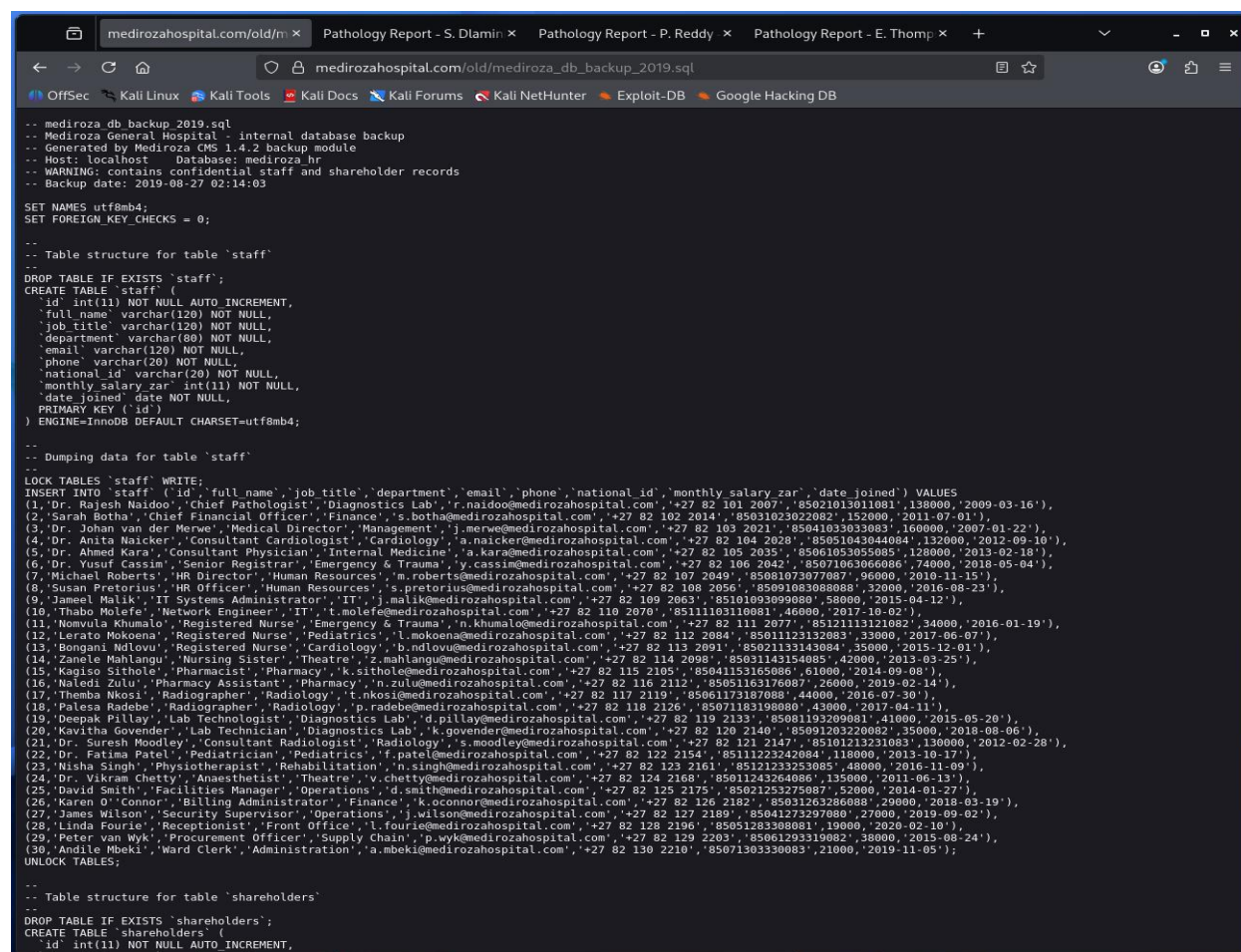
The /old/ directory referenced in the PDF metadata had already been identified during initial reconnaissance in Milestone 1, where it was observed to return a redirect response during directory enumeration, but had not yet been examined manually. Following the metadata disclosure in Finding 4, this directory was revisited and found to be fully accessible without any authentication whatsoever.

Within this directory, two highly sensitive business documents were discovered and retrieved without restriction, directly satisfying the Milestone 3 objective:

- A complete record of salary details for all hospital employees
- Shareholder details for Mediroza General Hospital

This finding represents a critical and complete failure to properly decommission data following a site migration. A directory explicitly noted internally as containing a database backup was left live on the production web server with no access control, directly exposing personal payroll data and confidential ownership and shareholder information to any unauthenticated party capable of locating the path.

Proof of Exploitation



```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011001',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',120000,'2013-02-10'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',35000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Thembu Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Patesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
```

```
medirozahospital.com/old/m x Pathology Report - S. Dlamini x Pathology Report - P. Reddy x Pathology Report - E. Thomp x +
medirozahospital.com/old/mediroza_db_backup_2019.sql
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

`date_joined` date NOT NULL,
PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.aidoo@medirozahospital.com','+27 82 101 2007','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022002',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033003',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044004',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055005',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066006',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077007',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088008',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099009',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110001',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132003',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143004',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154005',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165006',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176007',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187008',44000,'2016-07-30'),
(18,'Palessa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198009',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209001',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220002',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242004',110000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253005',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264006',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275007',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286008',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297009',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308001',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319002',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330003',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

4. Risk Rating

Each finding identified during this engagement has been assigned a risk rating of Critical, High, Medium, or Low, based on the sensitivity of the data or function affected, the ease with which the issue could be exploited by a realistic attacker, and the potential business impact to Mediroza General Hospital. A summary is provided in the table below, with detailed justification for each finding.

Finding	Milestone	Risk Rating	Justification
SQL Injection leading to Authentication Bypass on Patient Portal	M1	Critical	Allowed a fully unauthenticated attacker to bypass login controls and access restricted patient records, including confidential PDF lab reports. Direct compromise of confidentiality for protected health information.
Username Enumeration on Patient Portal Login	M1	Medium	Differential error messages allowed confirmation of valid usernames without authentication, supporting further targeted attacks such as credential stuffing or password spraying.
Weak, Crackable PDF Encryption Passwords	M2	High	Two of three confidential lab report PDFs were protected with passwords recoverable using a common wordlist within minutes, meaning the encryption provided little real protection for sensitive patient data.
Sensitive Data Exposure via Legacy Backup Directory (/old/)	M3	Critical	A publicly accessible, unauthenticated directory exposed highly confidential business data, including full staff salary details and shareholder information, with no access control whatsoever.
Information Disclosure via PDF Metadata	M3	Medium	Internal operational notes left in document metadata directly revealed the existence and location of a sensitive, improperly decommissioned backup directory, acting as the pivot point for the Critical finding above.

5. Recommendations and Remediation

5.1 SQL Injection and Authentication Bypass

- Rebuild all database queries in the application using parameterised queries or prepared statements. User supplied input must never be concatenated directly into SQL statements.
- Apply strict server side input validation and sanitisation to all authentication related fields.
- Conduct a full code review of the Mediroza CMS authentication module to identify and remediate any other instances of the same insecure query pattern.
- Deploy a Web Application Firewall configured to detect and block common SQL Injection patterns as a compensating control while remediation is completed.

5.2 Username Enumeration

- Standardise authentication error messages so that an identical, generic message, such as invalid username or password, is returned regardless of whether the submitted username exists.

- Implement rate limiting and account lockout controls on the Patient Portal login to slow down automated guessing attempts.
- Align the Patient Portal's error handling with the already correctly implemented behaviour observed on the Staff Login form.

5.3 Weak PDF Encryption Passwords

- Where patient health information must be distributed as password protected PDF files, enforce a strong, unique password policy for every document, with a minimum length and complexity that resists wordlist based attacks.
- Upgrade PDF encryption from RC4 128 bit to AES 256 bit, which is supported by current PDF standards and offers significantly stronger protection.
- Where feasible, deliver sensitive reports through an authenticated secure portal rather than as password protected file attachments, reducing reliance on password strength alone.

5.4 PDF Metadata and Document Hygiene

- Strip all unnecessary metadata, including internal comments and notes, from any document before it is generated for or made accessible to patients or external parties.
- Introduce a document release checklist or automated sanitisation step as part of the lab report generation process.
- Review staff practices and guidance around the use of comment and note fields in internal documents and backup procedures.

5.5 Legacy Backup Directory Exposure

- Immediately remove the /old/ directory and any other legacy or backup content from the live production web server.
- Establish a formal data migration and decommissioning procedure that requires verification that no legacy data remains publicly accessible before a migration is considered complete.
- Conduct a full audit of the web root for any other forgotten, legacy, or backup directories, informed by the directory and content discovery performed during this engagement.
- Store all database backups outside of the public web root, in a location that is never directly reachable over HTTP or HTTPS, and apply encryption and access control to backup storage at rest.

5.6 General Recommendations

- Schedule regular penetration testing and vulnerability assessments, particularly following any future site migrations or major application changes.
- Provide secure coding training to development staff, with particular emphasis on input handling, parameterised database access, and secure authentication design.
- Maintain an inventory of all directories and files present on the production web server, reviewed periodically to catch unintended exposure early.
- Retain the hardened configuration already observed on the mail services (SMTP relay restrictions and disabled VRFY enumeration) as an example of good practice to extend to other services.